CYBERSECURITY AVANZATA · LEZIONE 7 DI 8

Wireshark: leggere il traffico

I protocolli studiati per anni, finalmente visti pacchetto per pacchetto: DNS, handshake TCP, una password in chiaro e la stessa connessione protetta da TLS.

5G TPSI

Cattura, filtri di visualizzazione, DNS, TCP, HTTP in chiaro, TLS, che cosa resta visibile

PER COMINCIARE

Sei sulla Wi-Fi pubblica di un bar e apri https://www.wikipedia.org/wiki/Gatto. Che cosa vede chi gestisce la rete?

SONDAGGIO

- **A** Tutto, compresa la pagina sul gatto
- **B** Che sei su wikipedia.org, ma non quale pagina
- **C** Niente di niente
- **D** Solo il tuo indirizzo IP

PRIMA DI APRIRE IL PROGRAMMA

Che cosa si può catturare, e che cosa no

Lecito

- Il traffico del **tuo** PC, sulla tua rete o in laboratorio con il permesso del docente
- Il traffico di loopback dei tuoi programmi (localhost)
- File di cattura preparati per l'esercizio

Reato

- Intercettare le comunicazioni di altri, anche sulla Wi-Fi della scuola o di casa
- Installare programmi di cattura sui PC di altri
- Diffondere ciò che hai intercettato

> La legge italiana punisce l'intercettazione di comunicazioni informatiche: **art. 617-quater c.p.** In laboratorio si cattura solo sul proprio PC.

LO STRUMENTO

Wireshark in tre riquadri

1 · Elenco

Un pacchetto per riga: numero, tempo, origine, destinazione, protocollo, info.

2 · Dettagli

Il pacchetto scomposto per livelli: Ethernet, IP, TCP o UDP, applicazione. Si apre come un albero.

3 · Byte

Il pacchetto grezzo in esadecimale e ASCII: clic su un campo e si illumina.

Filtro di visualizzazione (barra in alto): nasconde quello che non serve, senza perdere nulla. Esempio `dns`.

Segui il flusso (tasto destro, Segui, TCP Stream): ricompone una conversazione intera.

AL COMPUTER · 20 minuti

Primo giro: DNS e handshake TCP

1. Apri Wireshark, doppio clic sulla scheda di rete in uso (quella con il grafico che si muove).
2. Nel Prompt: `ipconfig /flushdns`, poi apri **wikipedia.org** nel browser. Ferma la cattura (quadrato rosso).
3. Filtro `dns.qry.name contains "wikipedia"`: trova domanda e risposta. Quale IP?
4. Filtro `ip.addr == <quell'IP> && tcp.flags.syn == 1`: trova SYN e SYN-ACK.
5. Salva la cattura come **primo-giro-cognome.pcapng**.

Controllo: la risposta DNS contiene almeno un record **A** (IPv4) o **AAAA** (IPv6). Il SYN parte dal tuo PC verso la porta **443**; il SYN-ACK torna indietro poco dopo.

PUZZLE

Metti in ordine i pacchetti di una connessione HTTPS

1. TCP: SYN, ACK
2. TLS: Client Hello
3. TCP: SYN
4. TLS: Server Hello
5. DNS: richiesta del nome
6. DNS: risposta con l'indirizzo
7. TCP: ACK

IL GALATEO DEI PROTOCOLLI

Una regola scritta nel 1981

> **Sii prudente in ciò che fai, sii liberale in ciò che accetti dagli altri.**
>
> **Jon Postel**, curatore delle RFC di Internet, RFC 793 (TCP), 1981

Ha permesso a reti diversissime di parlarsi. Ma un server troppo "liberale" accetta anche pacchetti malformati: è così che nascono molti attacchi. Oggi si dice: **liberale sì, ma verifica tutto**.

AL COMPUTER · 30 minuti

Una password in chiaro, vista con i tuoi occhi

1. Avvia il server Java di un compito precedente (per esempio il guestbook o l'API con il token) su **http://localhost:8080**.
2. In Wireshark cattura sull'interfaccia **Adapter for loopback traffic capture**.
3. Invia un login o un messaggio con una password **inventata**, per esempio `Prova-Lab-123`.
4. Filtro `http.request.method == "POST"`, poi tasto destro, **Segui**, **HTTP Stream**.

Controllo: nel flusso, in rosso, leggi la richiesta POST intera, con la password **Prova-Lab-123** in chiaro. Chiunque fosse sul percorso la leggerebbe uguale.

PUZZLE

Abbina ogni filtro a ciò che mostra

`dns`	---	Solo i Client Hello
`tcp.port == 443`	---	Domande e risposte sui nomi
`tcp.flags.syn == 1 && tcp.flags.ack == 0`	---	Solo i tentativi di aprire una connessione
`tls.handshake.type == 1`	---	Il traffico verso o da HTTPS
`icmp`	---	I ping e i messaggi di errore della rete

AL COMPUTER · 20 minuti

La stessa cosa con TLS: che cosa resta visibile?

1. Cattura sulla scheda di rete mentre apri **https://www.wikipedia.org/wiki/Gatto**.
2. Filtro `tls.handshake.type == 1`: apri il Client Hello, cerca l'estensione **server_name**.
3. Segui il flusso TCP: si legge qualcosa della pagina o del percorso **/wiki/Gatto**?
4. In **wireshark-cognome.md** scrivi l'elenco di ciò che resta visibile e di ciò che è nascosto. Rispondi al sondaggio iniziale.

Controllo: nel Client Hello leggi **www.wikipedia.org** in chiaro. Il percorso e il contenuto non compaiono da nessuna parte: solo "Application Data" cifrati.

QUIZ A TRABOCCHETTO

Con una VPN commerciale attiva, sulla Wi-Fi del bar, chi può vedere il nome dei siti che visiti?

QUIZ

A Nessuno, la VPN rende anonimi

B Solo il gestore della Wi-Fi

C Il fornitore della VPN, al posto del gestore della Wi-Fi

D Tutti quelli collegati alla stessa Wi-Fi

AL COMPUTER · 15 minuti

Le statistiche: chi parla di più?

1. Riapri **primo-giro-cognome.pcapng** o fai una cattura di 2 minuti di navigazione normale.
2. Menu **Statistiche**, **Conversazioni**, scheda IPv4: ordina per byte.
3. Menu **Statistiche**, **Gerarchia dei protocolli**: quale percentuale è TLS? Quanta è DNS?
4. Annota i tre indirizzi con più traffico e prova a capire a quali servizi appartengono (nslookup inverso o i nomi DNS della cattura).

Controllo: TLS (o QUIC) occupa la gran parte dei byte; il DNS è una frazione minima dei byte ma tanti piccoli pacchetti.

OGGI

Il traffico è sempre più cifrato: e la difesa?





QUIZ

Nella cattura vedi 500 pacchetti SYN dal PC 10.0.3.27 verso 500 porte diverse di un server, in 2 secondi, e quasi nessun SYN-ACK. Che cos'è più probabile?

QUIZ

A Un aggiornamento di Windows

B Una scansione delle porte

C Un attacco DDoS

D Una videochiamata

SFIDA A SQUADRE

Apri il lucchetto



- 1ª e 2ª cifra: la porta del DNS
- 3ª e 4ª cifra: la porta di HTTP, quello in chiaro dove avete letto la password

codice

BIGLIETTO D'USCITA

Completa prima di uscire

Il driver che Wireshark usa su Windows per catturare si chiama _____.

Il primo pacchetto del three-way handshake è il _____.

Con HTTPS il nome del sito resta visibile nel campo _____ del Client Hello.

Intercettare le comunicazioni di altri è punito dall'articolo 617-_____ del codice penale.

Per ricomporre una conversazione si usa Segui _____.

⏱ 3:00

RIEPILOGO

Cosa portiamo a casa

- Si cattura solo il proprio traffico: il resto è reato
- Elenco, dettagli per livelli, byte; filtri di visualizzazione
- DNS, SYN, SYN-ACK, ACK, Client Hello
- HTTP: password leggibile da chiunque sul percorso
- TLS: visibili IP, SNI, tempi e dimensioni; nascosto il resto
- La VPN sposta la fiducia, non la elimina
- Statistiche e metadati: come lavora chi difende
- Prossima lezione: informatica forense

Hai una domanda su una slide? Usa il pulsante **? Domande** in basso: la vedrà il docente e tutta la classe.